



Presentación

Nombres:

Julio Cesar

Apellidos:

Hernández Tibrey

Matricula:

2025-0702

Carrera:

Seguridad informática

Materia:

Seguridad de redes

Tema:

Documentación Técnica

Docente:

Jonathan esteban rondón

Fecha:

5/06/2026

Link al video: <https://www.youtube.com/watch?v=MMt5WemRyXM>

Link al github: <https://github.com/Julio-Cesar-H-T/STP-Claim-Root>

Documentación Técnica: STP Root Claim — Secuestro del Root Bridge

Autor: Julio Cesar

Matrícula: 2025-0702

Fecha: 5 de junio de 2026

1. Objetivo Técnico

El propósito de este laboratorio es demostrar una vulnerabilidad en la capa de enlace de datos mediante el secuestro de la topología del protocolo *Spanning Tree* (STP). El ataque consiste en inyectar unidades de datos del protocolo de puente (BPDU) con una prioridad superior (valor numérico inferior) a la del switch legítimo, forzando una reconvergencia del árbol de expansión. Al convertirse en el nuevo *Root Bridge*, el nodo atacante logra redirigir el tráfico de la red a través de su interfaz, facilitando un escenario de interceptación *Man-in-the-Middle* (MitM) a nivel de Capa 2.

2. Especificaciones del Vector de Ataque

El ataque se ejecuta utilizando el script interactivo STP_Root_Attack.py, diseñado para construir y transmitir BPDUs de Configuración estándar IEEE 802.1D.

Nota Operativa: En la topología del laboratorio, la interfaz objetivo (E0/3) posee la protección bpduguard activada; para permitir la observación del vector de ataque, esta medida defensiva debe ser deshabilitada temporalmente por el administrador.

2.1. Parámetros de Configuración del Script

Parámetro	Valor Asignado	Descripción de la Función
Interfaz Físico	ens4	Interfaz de la máquina atacante (Kali Linux) conectada a la red.
Identificador VLAN	10	Identificador de la VLAN objetivo, cuyo valor se suma a la prioridad base.
Prioridad Base	0	Valor mínimo posible definido en el estándar STP.

Parámetro	Valor Asignado	Descripción de la Función
Prioridad Efectiva	10	Resultado de la prioridad base (0) más el Sys-ID-Ext (VLAN 10), garantizando la victoria sobre la prioridad 4106 del switch legítimo.
Temporizador (Hello Time)	2 s	Intervalo de inyección en bucle infinito para mantener la adyacencia como nodo raíz.

3. Funcionamiento y Estructura del Payload

3.1. Flujo Lógico de Ejecución

1. El script extrae la dirección MAC de la interfaz ens4 para utilizarla como identificador en los campos *Bridge ID* y *Root ID*.
2. Se construye un paquete BPDU IEEE 802.1D (35 bytes) manipulado con los siguientes parámetros críticos:
 - **Flags:** 0x01 indicando un cambio de topología (*Topology Change*).
 - **Root ID & Bridge ID:** Configurados con prioridad 10 seguida de la MAC del atacante.
 - **Root Cost:** 0, declarando explícitamente que el origen del paquete es la raíz del árbol.
 - **Message Age:** 0, confirmando la generación local.
3. El BPDU es encapsulado en una trama Ethernet:
 - **Dirección de Destino (DA):** MAC Multicast reservada para STP IEEE (01:80:C2:00:00:00).
 - **Cabecera LLC:** Identificadores DSAP=0x42 y SSAP=0x42 requeridos para el procesamiento de STP.
4. La trama se inyecta en la red cada 2 segundos a través de un socket L2 persistente.
5. Los switches receptores procesan el BPDU y comparan las métricas. Al evaluar que la prioridad efectiva del atacante (10) es estrictamente menor a la del *Root Bridge* actual (4106), la infraestructura acepta el cambio.

6. La red inicia un proceso de reconvergencia que interrumpe temporalmente el flujo de datos durante un lapso de 30 a 50 segundos.

3.2. Formato de Inyección sin Etiqueta (Untagged)

Debido a que el puerto del switch (E0/3) opera en modo de acceso (*access VLAN 10*), el protocolo dicta que los BPDUs deben transmitirse sin etiqueta de VLAN. El script omite la inserción de cabeceras 802.1Q y emplea la encapsulación LLC estándar para garantizar que el sistema operativo del switch (Cisco IOL) procese la trama como un mensaje de control válido.

4. Topología y Arquitectura de Red

El entorno distribuye las jerarquías de conmutación donde SW-1 opera como el centro lógico de la red.

Entidad	Rol Operativo	Identificador (Bridge ID)	Capacidad de Dominio
SW-1	Root Bridge Legítimo	Prioridad Efectiva: 4106 / MAC: aabb.cc00.0300	Administra las VLANs de acceso.
Kali	Atacante (E0/3)	Prioridad Efectiva: 10 / MAC: <MAC de ens4>	Inyecta tráfico por el puerto en acceso de la VLAN 10.

Previo al ataque, el comando `show spanning-tree vlan 10` en SW-1 confirma el estado nominal con la bandera *This bridge is the root*. Durante el ataque, la validación refleja que el Root ID ha cambiado hacia la MAC del atacante y el puerto raíz (*Root port*) se recalcula hacia Et0/3.

5. Evidencias de Ejecución

(Nota para la maquetación del PDF: Insertar las siguientes capturas de pantalla en esta sección)

1. Estado topológico en SW-1 (`show spanning-tree vlan 10`) previo a la inyección, corroborando su rol como *Root Bridge*.
2. Terminal activa en la máquina atacante evidenciando la generación de BPDUs y el avance del contador de inyecciones.
3. Validación en SW-1 confirmando la alteración del identificador raíz y la degradación del switch a un rol subordinado.

4. Registro de inestabilidad de red a través de `show spanning-tree vlan 10 detail`, demostrando un incremento sostenido en los contadores de *Topology changes*.
5. Evidencia de pérdida de conectividad durante la reconvergencia mediante tiempos de espera (*timeouts*) en una prueba de latencia (ping) continua entre VPC-1 y VPC-2.

6. Estrategias de Mitigación y Contra-medidas

La manipulación de la topología STP se previene implementando características de seguridad perimetral dentro del árbol de expansión.

6.1. Habilitación de BPDU Guard (Defensa de Acceso)

Es la contramedida principal para puertos orientados al usuario final. Si el puerto recibe cualquier BPDU, es inmediatamente bloqueado y colocado en estado de error (*err-disabled*).

Plaintext

! Activación a nivel de interfaz

```
SW-1(config)# interface Ethernet0/3
```

```
SW-1(config-if)# spanning-tree bpduguard enable
```

! Despliegue global en combinación con PortFast

```
SW-1(config)# spanning-tree portfast bpduguard default
```

(Nota: Para recuperar el puerto tras una violación, es necesario aplicar la secuencia administrativa shutdown y no shutdown).

6.2. Implementación de Root Guard (Defensa de Distribución)

Se aplica en los enlaces ascendentes (*uplinks*) hacia switches de menor jerarquía para prevenir que intenten asumir el control del árbol. Si se intercepta un BPDU con métricas superiores, el puerto transiciona a un estado *root-inconsistent* en lugar de aceptar al nuevo líder.

Plaintext

```
SW-1(config)# interface Ethernet0/1
```

```
SW-1(config-if)# spanning-tree guard root
```

La auditoría de estas protecciones se realiza monitoreando los puertos afectados utilizando las consultas `show spanning-tree summary`, `show interfaces Ethernet0/3`

status y revisando los bloqueos lógicos mediante show spanning-tree inconsistentports.

Evidencia:

```
VLAN0010
Spanning tree enabled protocol ieee
Root ID    Priority    4106
           Address    aabb.cc00.0300
           This bridge is the root
           Hello Time  2 sec  Max Age 20 sec  Forward Delay 15 sec

Bridge ID  Priority    4106 (priority 4096 sys-id-ext 10)
           Address    aabb.cc00.0300
           Hello Time  2 sec  Max Age 20 sec  Forward Delay 15 sec
           Aging Time  300 sec

Interface                Role Sts Cost      Prio.Nbr Type
-----
Et0/0                    Desg FWD 100       128.1    P2p Edge
Et0/1                    Desg FWD 100       128.2    P2p
Et0/3                    Desg FWD 100       128.4    P2p
```

```
user@user-pc:~/Ataques$ sudo python3 STP_Root.py
[+] Inyectando BPDUs planas en ens4 hacia puerto de acceso...
```

```
SW-1#show spanning-tree vlan 10

VLAN0010
Spanning tree enabled protocol ieee
Root ID    Priority    10
           Address    50b5.2500.0901
           Cost        100
           Port        4 (Ethernet0/3)
           Hello Time  2 sec  Max Age 20 sec  Forward Delay 15 sec

Bridge ID  Priority    4106 (priority 4096 sys-id-ext 10)
           Address    aabb.cc00.0300
           Hello Time  2 sec  Max Age 20 sec  Forward Delay 15 sec
           Aging Time  15 sec

Interface                Role Sts Cost      Prio.Nbr Type
-----
Et0/0                    Desg FWD 100       128.1    P2p Edge
Et0/1                    Desg FWD 100       128.2    P2p
Et0/3                    Root FWD 100       128.4    P2p
```